API Workflows - E-commerce Store

Weekend 1 | Deliverable 04. All routes come from the project's urls.py files. Auth = JWT in httpOnly cookies (access 15 min, refresh 7 days). "D-xx" refers to the Defects sheet in 05_test-cases.xlsx. Request/response field names marked * are inferred from the views and tests and should be confirmed against the serializers.

1. Endpoint catalogue

#	Method	Route	Auth	What it does	Success	Main error cases
1	POST	/signup/	No	Create user in default tenant (id=2)	201 {info}	400 invalid/duplicate/missing; 500 if tenant 2 missing (D-02); weak password accepted (D-01)
2	POST	/login/	No	Validate credentials, set httpOnly access (15 min) + refresh (7 d) cookies	200 (tokens only in cookies)	400 missing field; 401 wrong credentials / inactive user
3	POST	/token/refresh/	No (cookie)	Issue a new access cookie from refresh cookie	200 {success:true}	401 cookie missing; 401 invalid/expired/wrong token type
4	POST	/logout/	Cookie	Delete access + refresh cookies (tokens are not blacklisted)	200 {info}	405 other methods
5	GET	/status/	No	Is the access cookie valid?	200 {authenticated:bool}	Bad/expired cookie returns 401 instead of false (D-03)
6	GET	/products/	Yes	Tenant-scoped list: search, filters, ordering, pagination, Redis cache 300 s	200 paginated	401/403 no auth; 404 page beyond last; bad min/max price ignored
7	POST	/products/	Yes	Create product (tenant taken from user)	201	400 missing/invalid/duplicate SKU; negative price accepted (D-09); any user can create (D-07)
8	GET	/products/{id}/	Yes	Product detail incl. images, tags, stock	200	404 inactive/deleted/other tenant/unknown
9	PUT/PATCH	/products/{id}/	Yes	Update product, clears tenant cache	200	400 validation; 404 other tenant; no role check (D-07)
10	DELETE	/products/{id}/	Yes	Soft delete (is_deleted=true), clears cache	204	404 if already deleted/other tenant
11	GET	/inventory/	Yes	List stock rows	200	Not tenant-scoped (D-06); unordered (D-10)
12	POST	/inventory/	Yes	Create stock row for a product	201	400 negative/non-integer/unknown product; duplicate row gives 500 (D-05); cross-tenant allowed (D-06)
13	GET/PUT/PATCH/DELETE	/inventory/{id}/	Yes	Read/change/delete a stock row	200/204	404 unknown id; cross-tenant and non-staff allowed (D-06, D-07)
14	POST	/cart/add/	Yes	Add product (+size/color) to the caller's cart; creates cart if missing	201 {info}	400 bad/zero/negative quantity, no stock, stock exceeded on repeat add; 404 product not found/inactive/other tenant; first add above stock accepted (D-04)
15	GET	/cart/	Yes	Return cart with items	200	401/403
16	PATCH	/cart/items/{product_id}/	Yes	Change quantity of a cart line (checks stock)	200 {info}	400 invalid qty / above stock; 404 product or line not found
17	DELETE	/cart/{product_id}/	Yes	Remove a line from the cart	200 {info}	404 not in cart; inactive product cannot be removed (D-11 suspected)

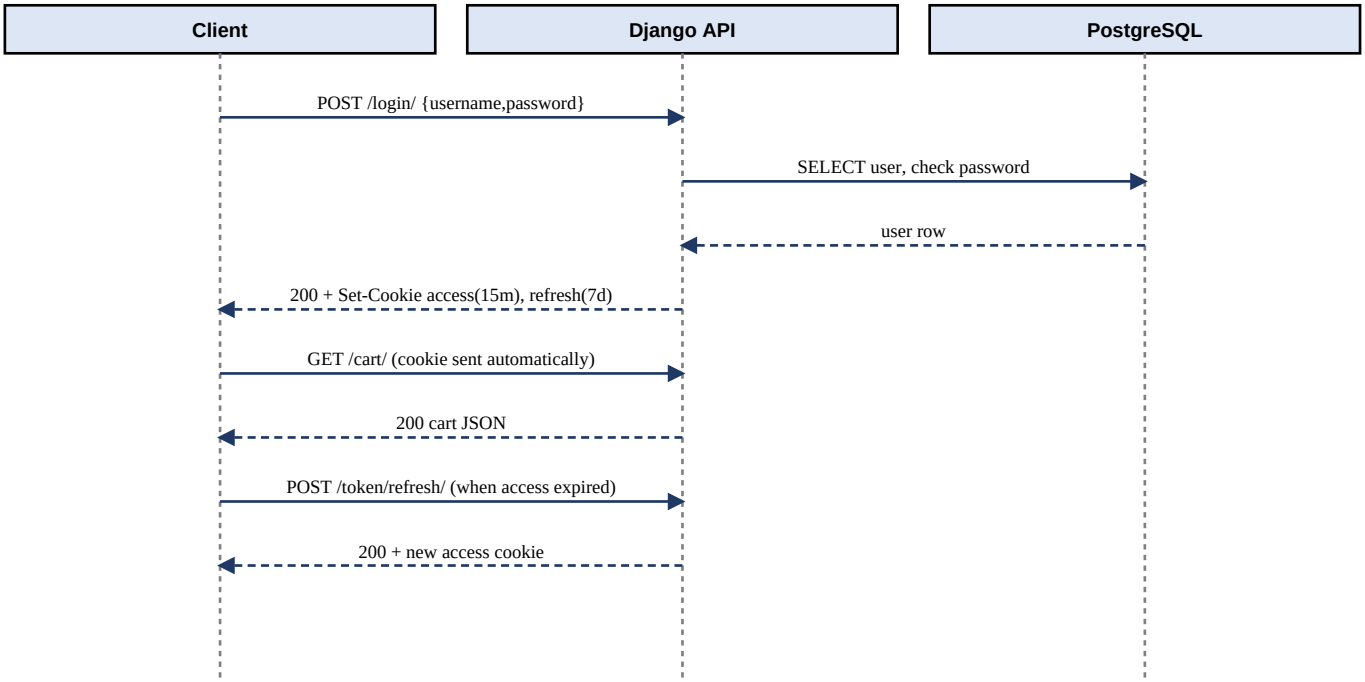
#	Method	Route	Auth	What it does	Success	Main error cases
18	POST	/order/checkout/	Yes + Idempotency-Key header	Atomic checkout: lock stock, create order+items, mock charge, record payment, mark PAID, empty cart, clear cache	201 new / 200 replay	400 missing key / empty cart / out of stock; 402 payment declined; 404 no cart / no stock row; 503 gateway down; deleted product still buyable (D-08)
19	GET	/orders/	Yes	Caller's order history, newest first	200	401/403
20	GET	/api/schema/ , /api/docs/	No	OpenAPI schema and Swagger UI (drf-spectacular)	200	-

2. Request / response examples

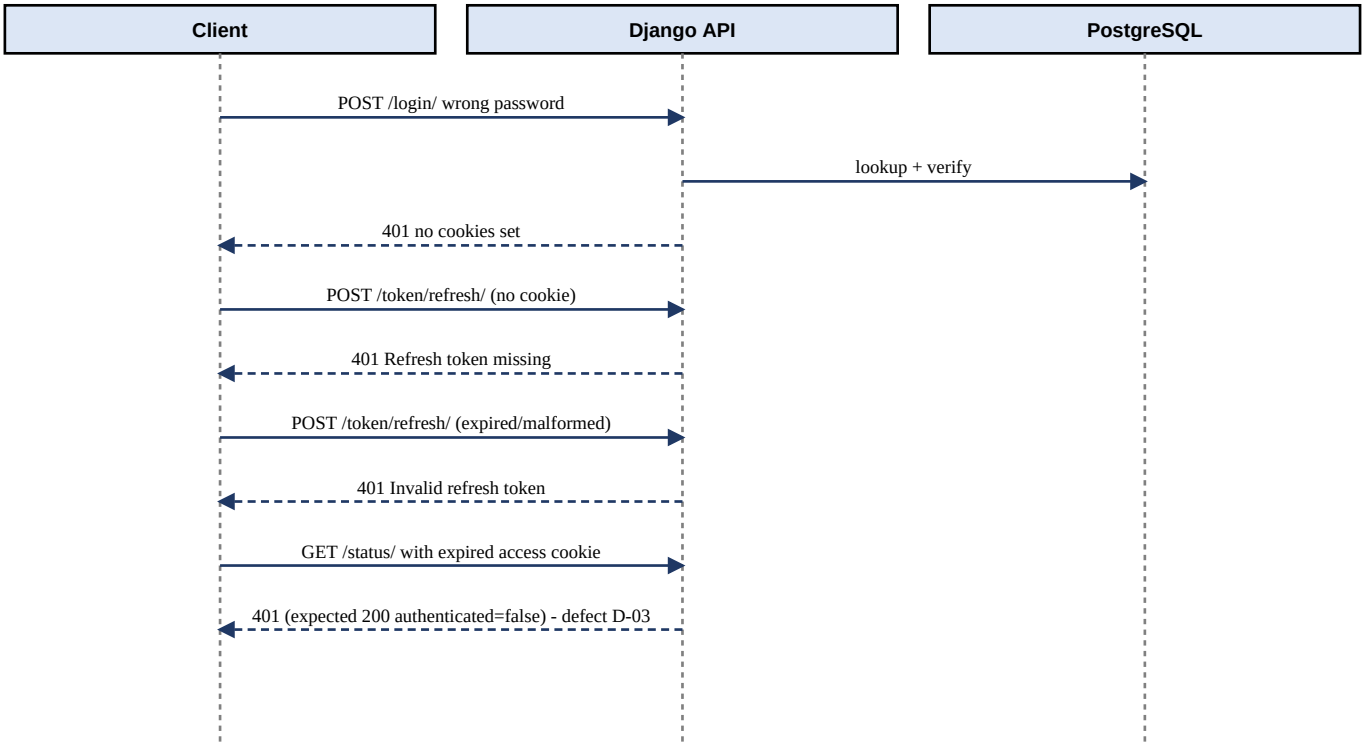
Endpoint	Request	Response
POST /signup/	{"username":"alice","email":"a@x.com","password":"S3cretPass!"}*	201 {"info":"User created successfully!"} 400 {"username":["A user with that username already exists."]}
POST /login/	{"username":"alice","password":"S3cretPass!"}	200 {} + Set-Cookie: access, refresh (HttpOnly, SameSite=Lax) 401 {"detail":"No active account found with the given credentials"}
POST /token/refresh/	(no body; refresh cookie)	200 {"success":true} + new access cookie 401 {"detail":"Refresh token missing"} / {"detail":"Invalid refresh token"}
GET /status/	(cookies)	200 {"authenticated":true}
GET /products/?search=hoodie&min;_price=10&ordering;=-price&page;=1&page;_size=20	(cookies)	200 {"count":..,"next":..,"previous":..,"results":[...]}
POST /products/	{"name":"Hoodie","price":"49.99","category":1,"tags":[1],"sku":"HD-001","specifications":{"color":"red","size_stock":{"M":5,"L":3}}}*	201 product JSON 400 {"sku":["product with this sku already exists."]}
POST /inventory/	{"product":1,"stock":10}*	201 {...} 400 {"stock":["Ensure this value is greater than or equal to 0."]}
POST /cart/add/	{"product_id":1,"quantity":2,"size":"M","color":"red"}	201 {"info":"Product added to cart"} 400 {"error":"Total quantity exceeds available stock (5)"} 404 {"detail":"Not found."}
PATCH /cart/items/1/	{"quantity":3}	200 {"info":"Quantity updated!"} 400 {"error":"Quantity exceeds available stock (5)"}
DELETE /cart/1/	-	200 {"info":"Item removed!"}
POST /order/checkout/	Header Idempotency-Key: 7c1e... ; body {"payment_token":"tok_success"}	201 {"message":"Order placed successfully!","order_id":12,"total_price":59.97} 200 same body on replay 402 {"error":"Payment failed: ..."} 503 {"error":"Payment service unavailable. Please try again."}
GET /orders/	(cookies)	200 [{id,status,total_price,items:[...]} ...]

3. Sequence diagrams

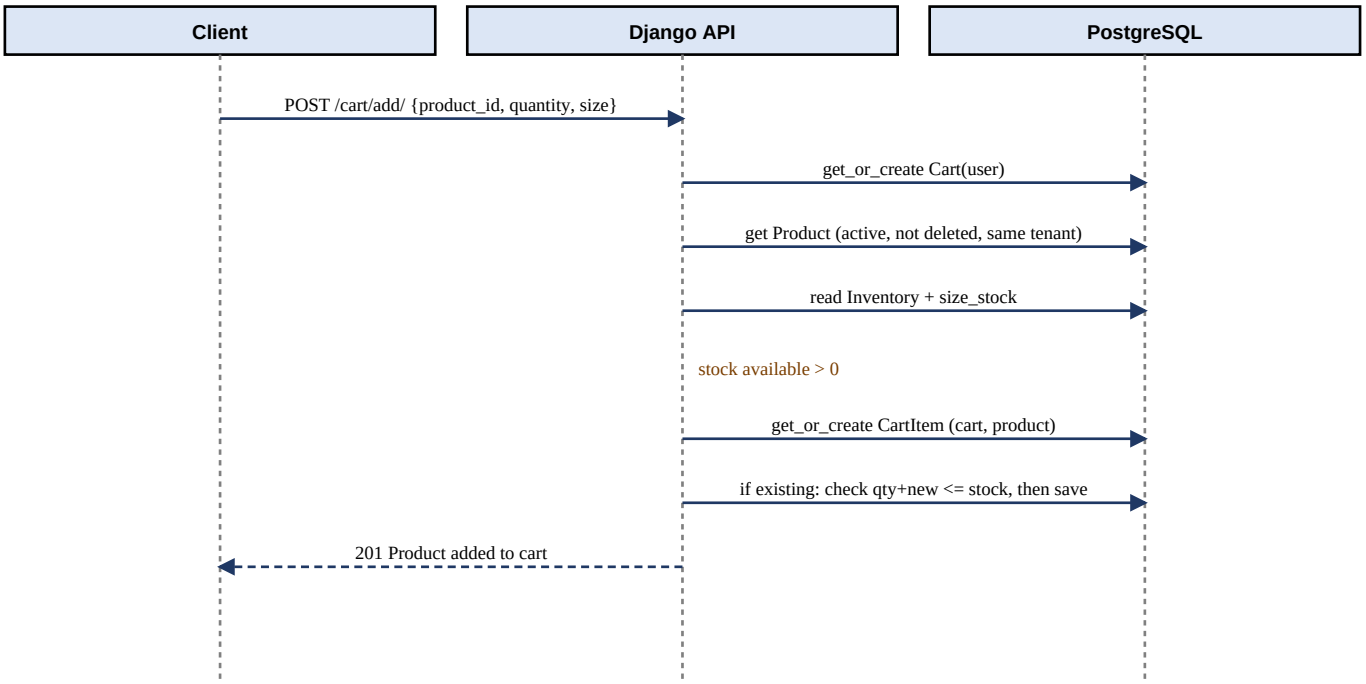
3.1 Login, authenticated call, silent refresh (success)



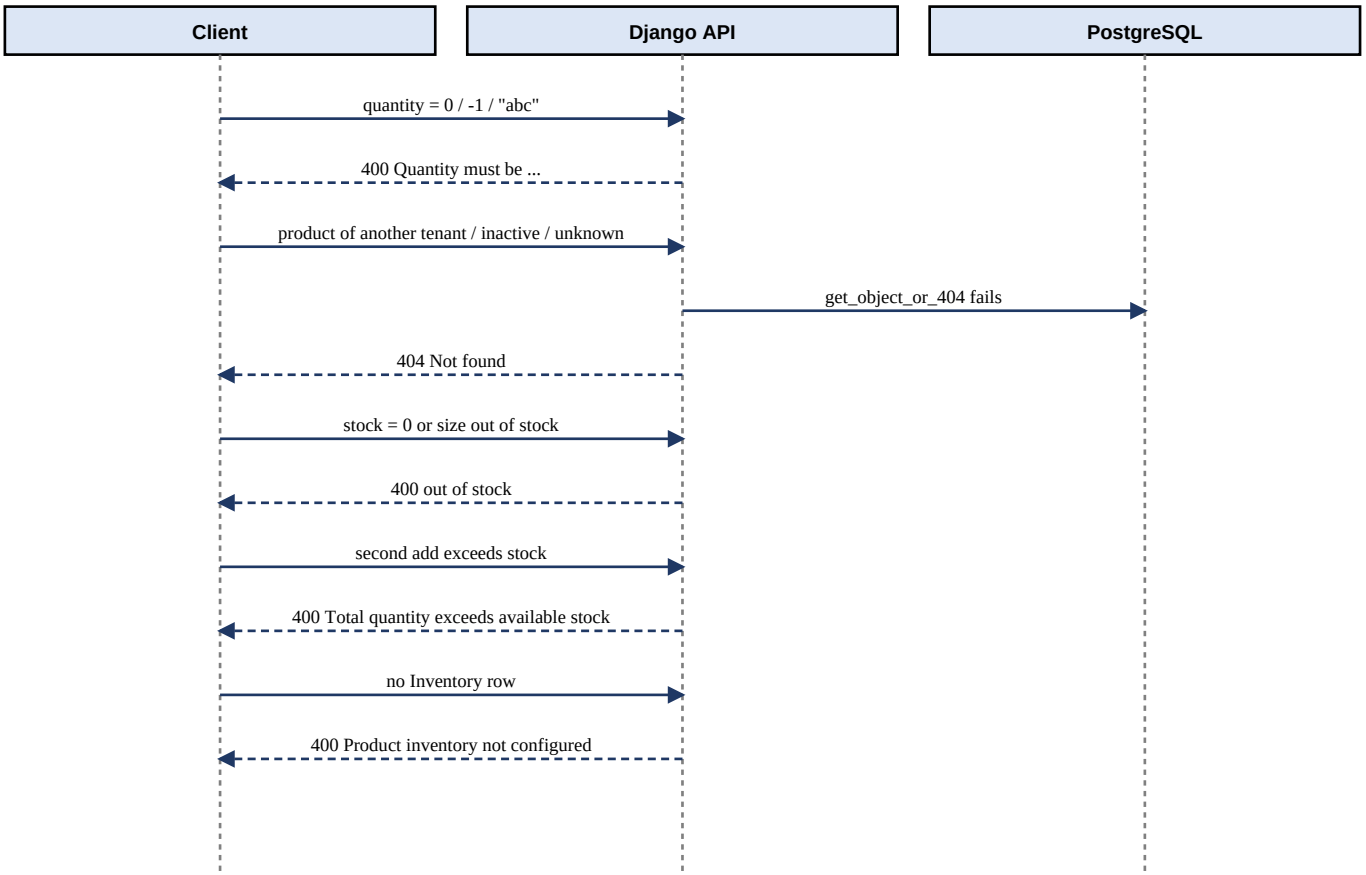
3.2 Login / refresh failure paths



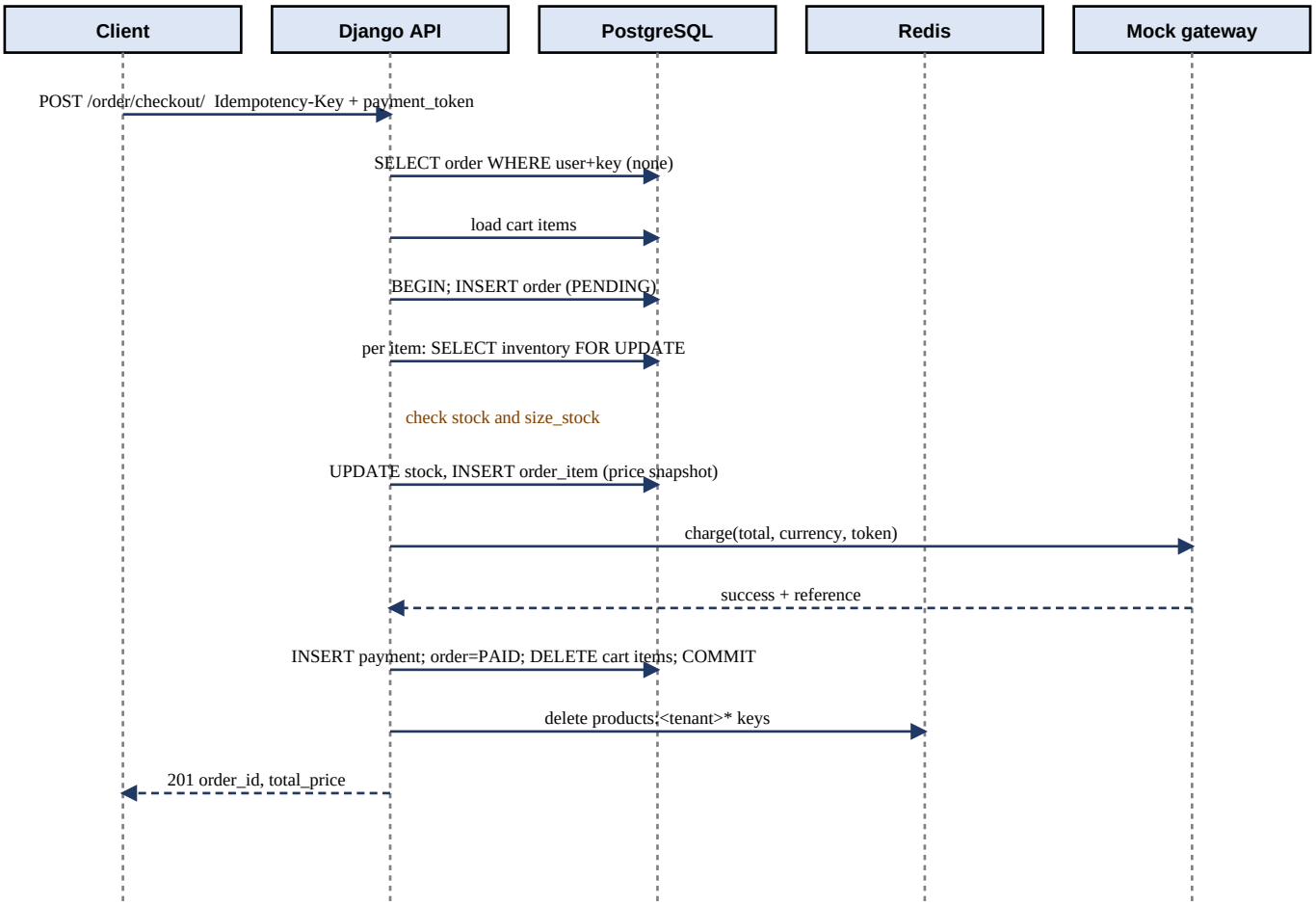
3.3 Add to cart - success



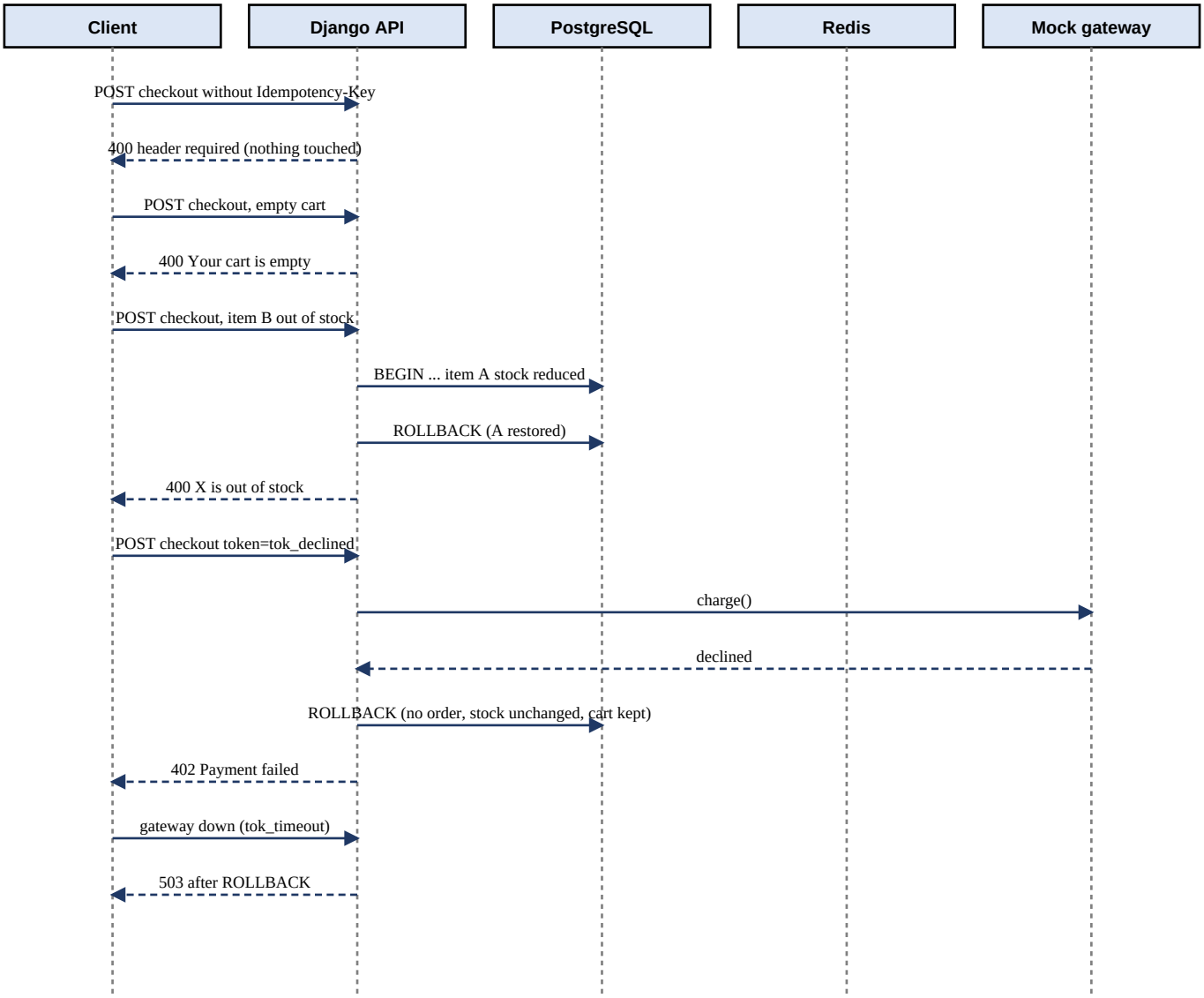
3.4 Add to cart - failure paths



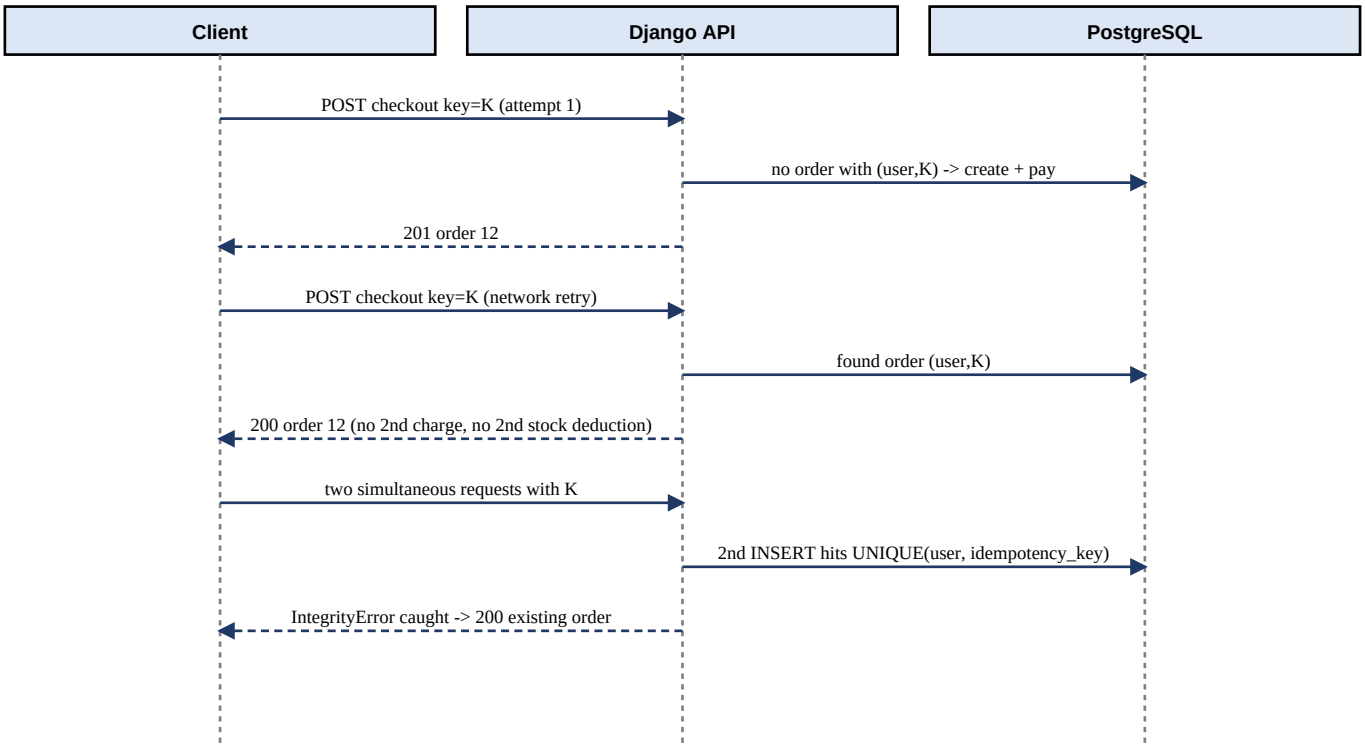
3.5 Checkout - success path (201)



3.6 Checkout - failure paths with full rollback


Client
Django API
PostgreSQL
Redis
Mock gateway
POST checkout without Idempotency-Key
400 header required (nothing touched)
POST checkout, empty cart
400 Your cart is empty
POST checkout, item B out of stock
BEGIN ... item A stock reduced
ROLLBACK (A restored)
400 X is out of stock
POST checkout token=tok_declined
charge()
declined
ROLLBACK (no order, stock unchanged, cart kept)
402 Payment failed
gateway down (tok_timeout)
503 after ROLLBACK

3.7 Duplicate / retry protection (idempotency)



Notes: diagrams are rendered from code for this PDF. To get editable Lucidchart versions, recreate them from the message lists above (or import Mermaid via Lucidchart's diagram-as-code feature if enabled on your account).